

IDS A IPS SYSTÉMY

Firewall versus IDS/IPS

- Firewall je jen filtr
 - Neodliší nelegitimní provoz od legitimního
 - Neochrání před bezpečnostními problémy vzniklými uvnitř sítě
 - Nelze se „zazdít“
 - servery musí poskytovat služby
 - uživatelé je chtějí využívat

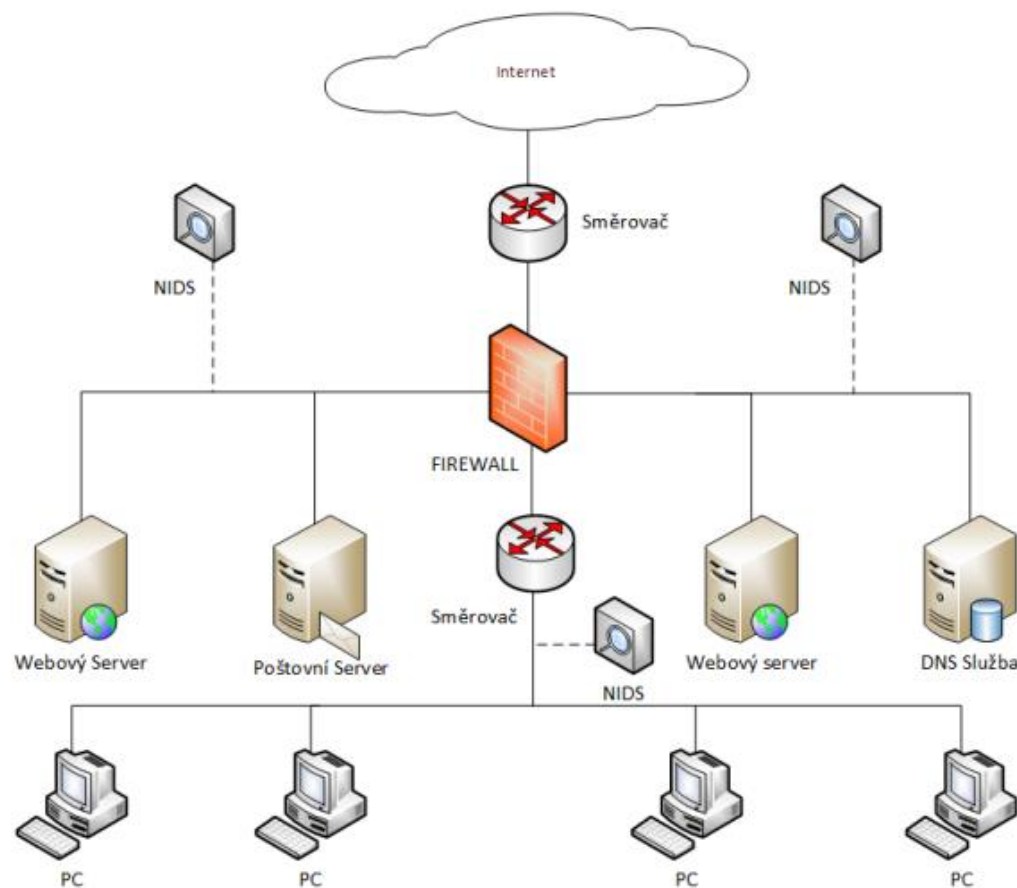
IDS x IPS

- Inspection Detection Systém
 - Přijímá klonovaný provoz (SpanPort / TAPbox)
 - Informuje správce sítě či konkrétního stroje
 - Je pasivní, nezasahuje do provozu
- Inspection Prevention Systém
 - Zařízení umístěné v lince
 - Informuje správce, navíc blokuje nežádoucí komunikaci
 - Je aktivní, zasahuje do provozu

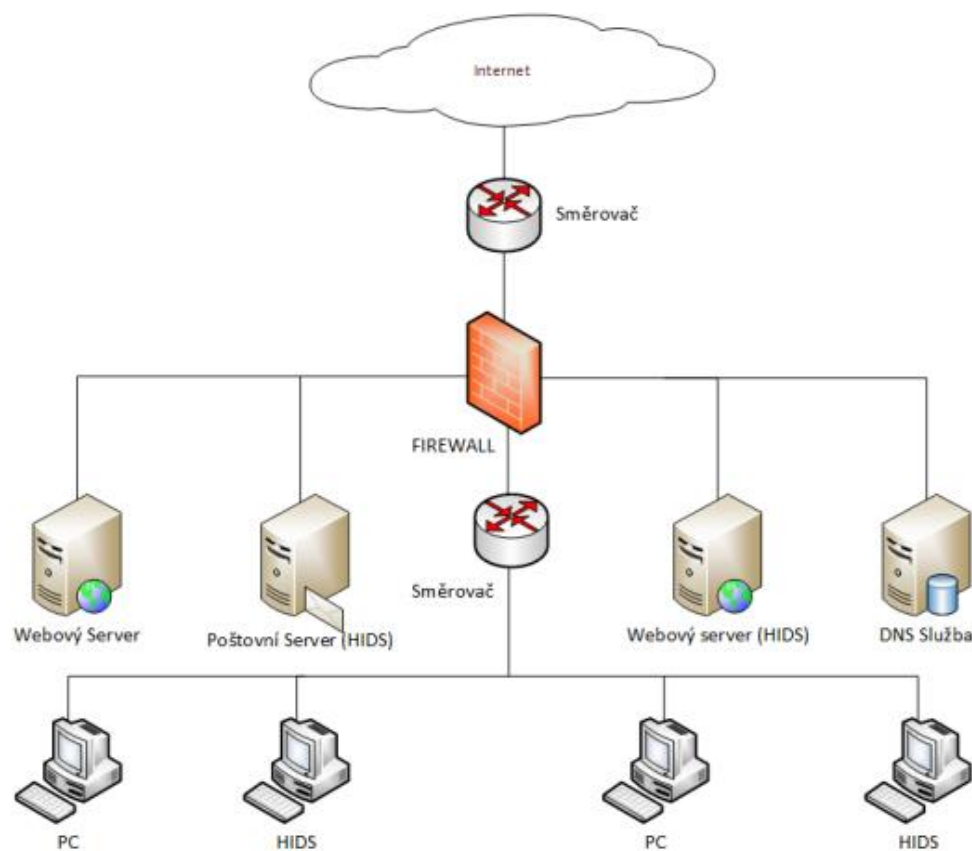
IDS

- Překonaná technologie, bez preventivního účinku
 - Útok se prožene sítí dříve, než si ho člověk všimne
 - Objem událostí bývá obrovský
- Přetrvávající smysl
 - Výzkum, statistiky provozu (sledování určitého typu událostí)
 - Inspekce v menších segmentech s méně událostmi
 - Sonda pro korelující distribuovaný systém

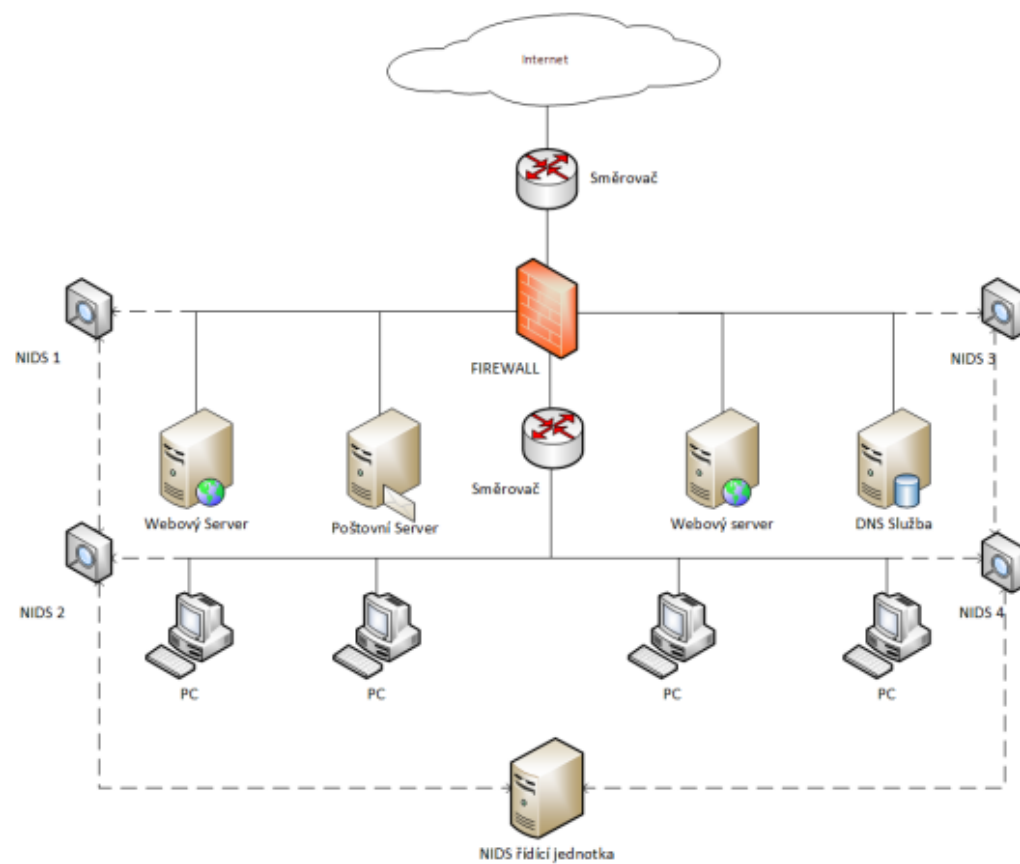
Network intrusion detection system (NIDS)



Host intrusion detection system (HIDS)



Distributed intrusion detection system (DIDS)



IPS

- Aktivně chrání síť
 - Závažné incidenty jsou blokovány
 - Méně závažné monitorovány
 - „Provinilé“ IP adresy lze umístit do karantény
 - Karanténu lze sdílet prostřednictvím reputační databáze
 - Spolupráce s NMS, přesun stanic do karanténní VLAN, zrušení 802.1X autentizace, apod.

Princip sledování

- I[DP]S – Provádí hloubkovou inspekci paketů
 - Sleduje především payload paketů
 - S hledáním jde až do aplikační vrstvy
 - Koreluje současný provoz s „nedávným“, vidí souvislosti
- Provoz sleduje
 - V síti (NIDS)
 - Na serveru / stanici (HIDS)

Práce IDS a IPS

- I[DP]S nahlíží do provozu
 - Běžného
 - Tunelovaného
 - Šifrovaného
 - Klonování provozu VPN před zabalením
 - Úložiště privátních klíčů
- Hledání
 - Exploitů, skenování, porušení firemních pravidel, distribuovaných útoků

Inspekce provozu

- Hledání signatur
 - Obdoba vyhledávání řetězců antivirem
 - Vícestupňové hledání
 - Zmenšuje latenci
 - Nejprve krátký řetězec
 - Je-li nalezen, následuje důkladnější kontrola
- Stavové hledání
 - Několik navazujících hledání v rámci komunikace

Detekce anomálií

- Nezvyklá komunikace v síti
 - Špatná délka zprávy, nesprávné kontrolní součty
 - Neobvyklý obsah zprávy
 - Nenavazující data v rámci komunikace
 - Datagramy nepatřící žádnému spojení
- Síťový provoz vymykající se normálu
 - Navzorkování „běžné“ komunikace
 - Statistické porovnání s běžným stavem

Detekce sadou pravidel

- Nejsofistikovanější inspekce vyspělejších zařízení
 - Korelace událostí, simulace lidského uvažování (fuzzy logic)
 - Schopnost nalézt i velmi nenápadné průniky
 - Odhalení „Zero Day“ útoků

Zásah IPS

- Pokud filtr zjistí bezpečnostní událost
 - Nahlásí ji (jako IDS)
 - Zablokuje datový tok
 - Umístí útočníka do karantény
 - Povolí provoz (white listing)
 - Omezí datový tok (sníží přenosové pásmo)
 - Přesměruje datový tok do jiné VLAN
 - Zásah na síťovém prvku přes NMS
 - Kombinace

Karanténa a reputace

- Lokální karanténa
 - IP adresy na kterých byl proveden nedávný zásah
 - Může být sdílena dalšími uživateli IPS / IDS
- Reputační databáze
 - Sdílený seznam problémových IP adres a DNS adres
- Při přístupu uživatele prohlížečem na adresu v karanténě dojde k přesměrování na stránku s upozorněním
- Zásah IPS pokud je
 - Komunikováno s IP adresou v lokální karanténě
 - Komunikováno s IP adresou z reputační databáze
 - Použita závadná DNS adresa z reputační databáze

K čemu IDS a IPS neslouží

- K monitorování služeb v síti
- K omezení přístupu, autorizace
- K antivirová ochrana
- K zabezpečení síťové vrstvy a síťových protokolů
- Zamezení DDoS útokům
- K „špehování“ uživatelů

Implementace

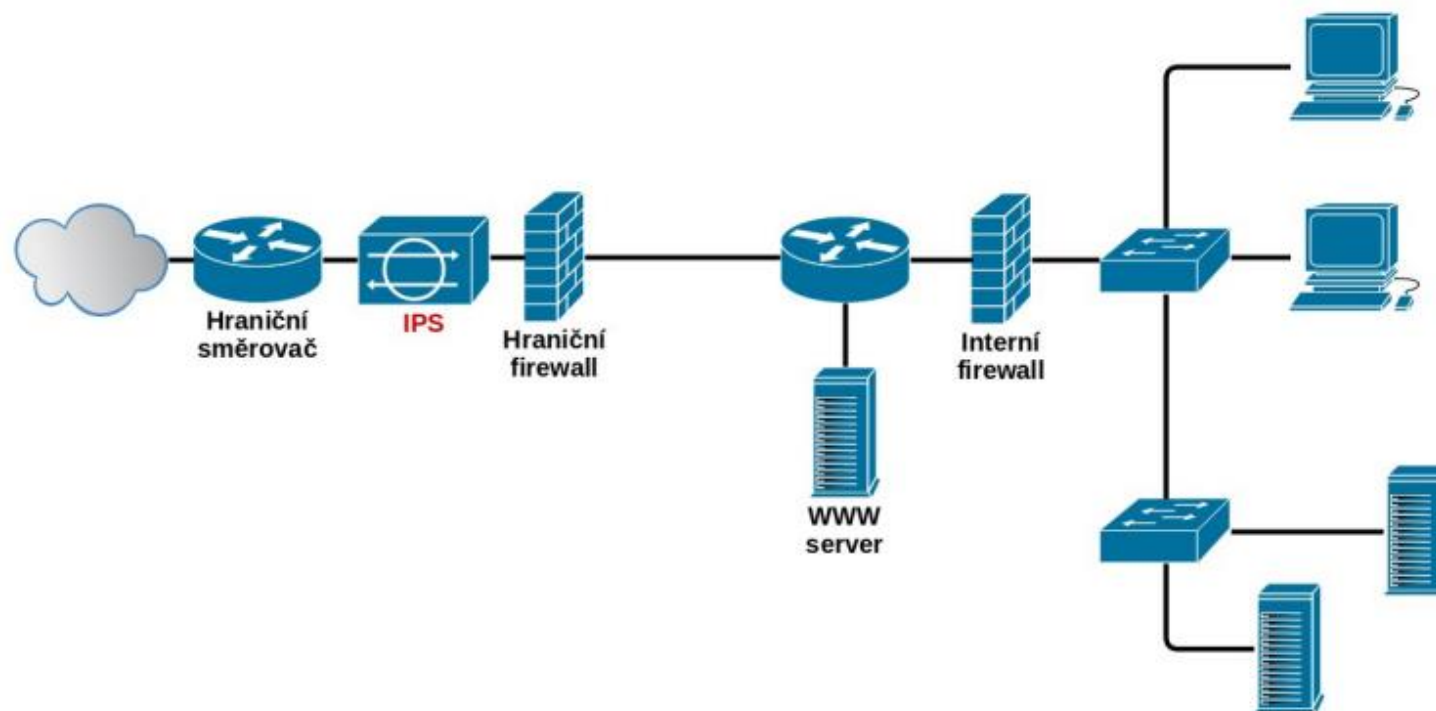
- IDS
 - PC s rychlou síťovou kartou, svobodný / placený SW
 - PC s HW kartou – sondou
 - HW IDS
- IPS
 - IDS software v režimu IPS (na Linuxu prostřednictvím IPTables a NFQueue)
 - Komerční řešení se softwarovou inspekci
 - Firewall doplněný softwarovým IPS modulem
 - Kompletně hardwarové řešení s inspekci realizovanou hradlovými poli a síťovými procesory

Nasazení

- Vně perimetru sítě
- Za první firewall
- Před síťový segment
 - Ochrana serverové farmy
 - Ochrana uživatelských stanic
- Sonda uvnitř sítě

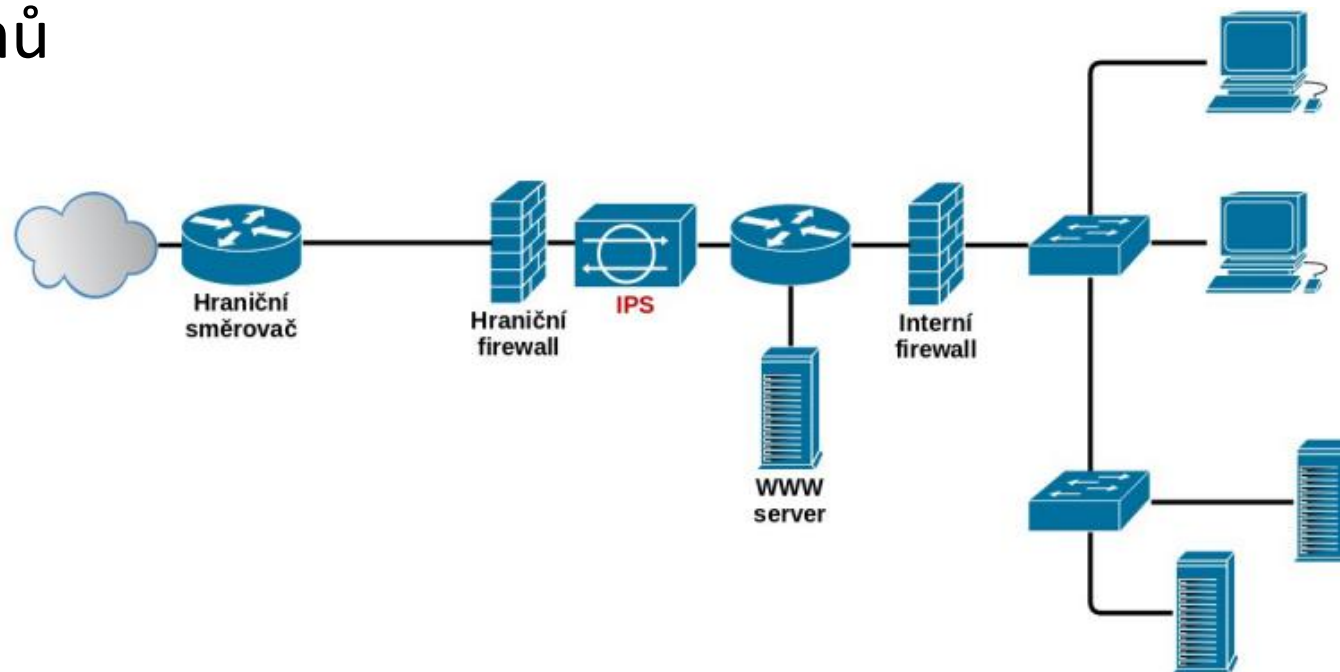
IPS před perimetrem

- Vidíme vše, co nás může ohrozit
- Značný provoz, nepřehledný monitoring
- Není obvyklé



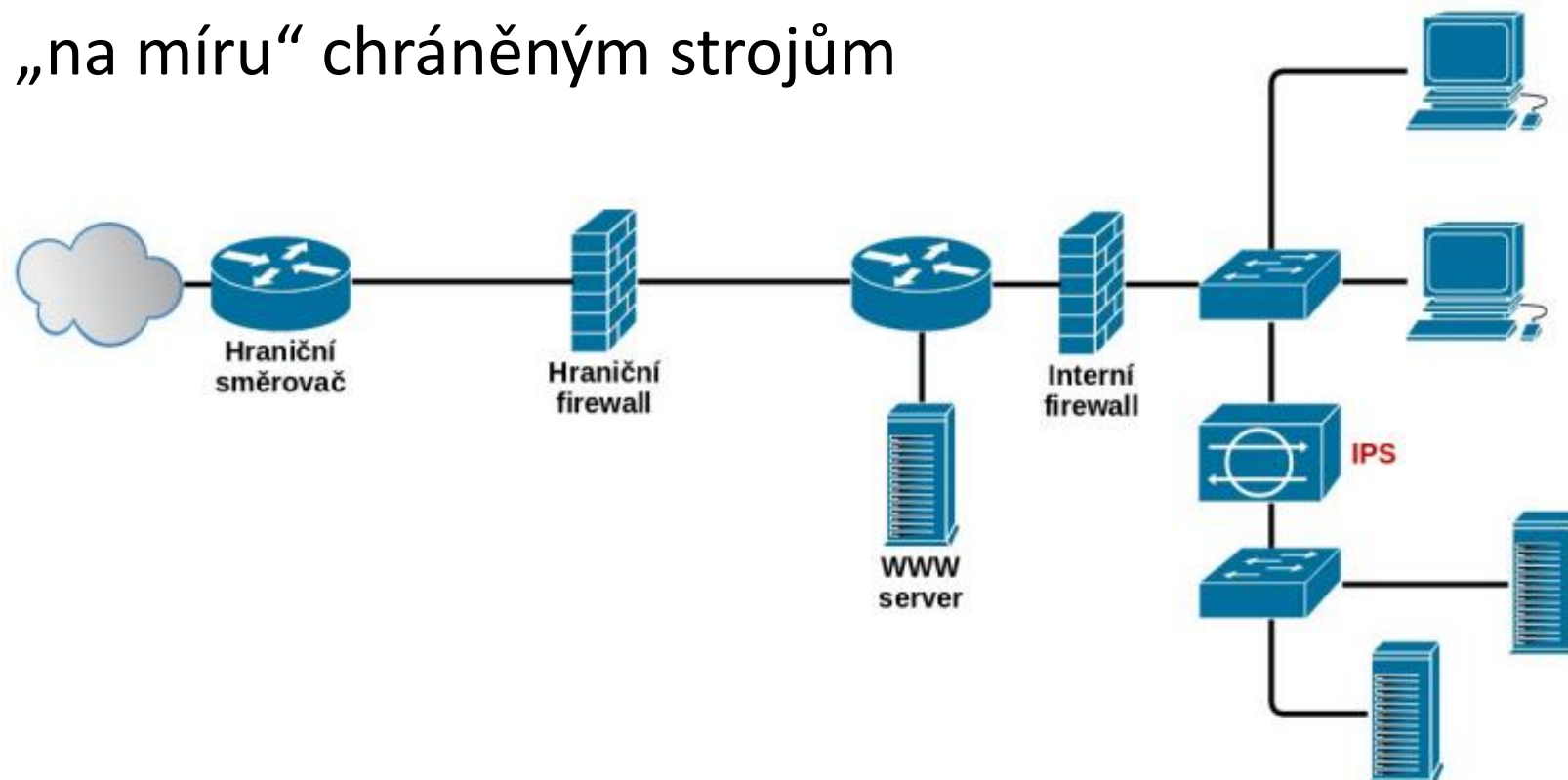
IPS před DMZ

- IPS je předřazen firewall
- Velké nároky na výkon inspekce
- Ochrana různých systémů
- Běžné nasazení



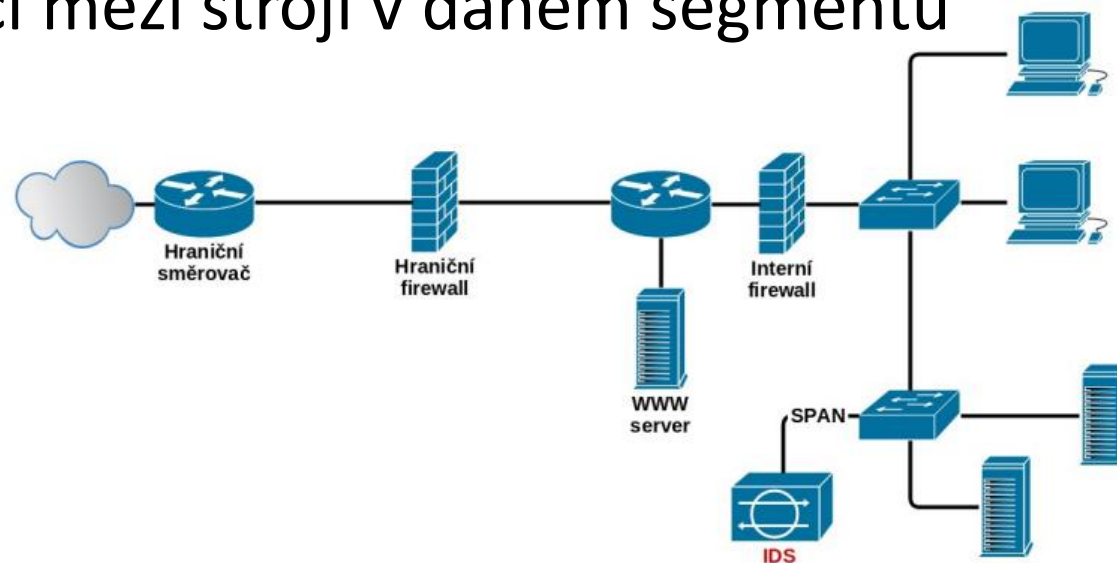
IPS před síťovým segmentem

- Menší provoz, nižší nároky na výkon inspekce
- Konfigurace IPS „na míru“ chráněným strojům



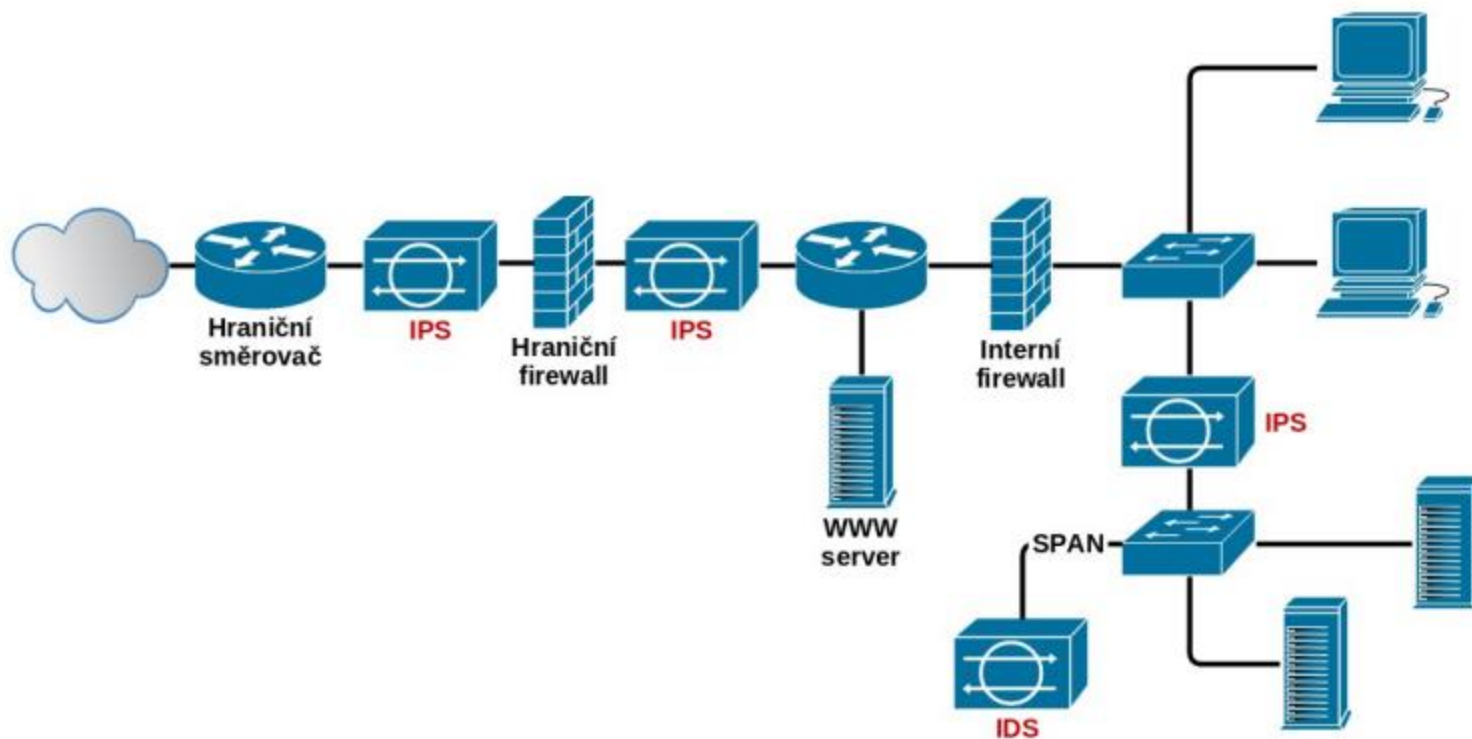
IDS sonda uvnitř sítě

- Sledování konkrétních anomálií v lokální síti
- Některé závadné chování se neprojeví, pokud je komunikace ovlivňována firewallem a IPS
- Nalezení problémů v komunikaci mezi stroji v daném segmentu



Více zařízení

- Nasazení IPS / IDS bývá kombinováno



Výběr komerčního produktu

- Kritéria pro výběr IPS
 - Propustnost
 - Výkon inspekce
 - Vysoká dostupnost
 - IPv6
 - Aktualizace firmware / pravidel / reputační databáze
 - Reakce na aktuální hrozby
 - Snadná správa, 365 / 7 / 24 podpora
 - Životnost zařízení
 - Certifikace (ICSA Labs, ...)
 - Recenze
 - Testování

Nasazení zařízení

- Prvotní konfigurace a „vyladění“ vyžaduje mnoho času
 - Příprava uživatelů
 - Analýza sítě
 - Úklid v síti
 - Instalace
 - Konfigurace
 - Výběr pravidel
 - Sledování provozu
 - Optimalizace zásahů pravidel, propojení s infrastrukturou



Nesnáze s uživateli

- Uživatelé se mohou bouřit
 - Je to „blackbox“, nemáme nad tím žádnou moc
 - „budu omezován“
 - „budu špehován“
 - „nechci svá data posílat NSA“
 - „co když to přestane fungovat“
- V provozu může být jakýkoliv problém svalen na IPS a jeho správce

SW řešení

- Nechci / nemohu investovat do HW řešení
 - Méně výkonné komerční produkty
 - SW IPS na bázi PC bez HW akcelerace inspekčního procesu
 - Bezplatné SW IDS / IPS sondy
 - Snort
 - Suricata
 - Sagan
- Sada pravidel
 - Vytvářených komunitou
 - Placených, dodávaných tvůrci

Snort

- Vyvíjen již od roku 1998
- Nyní produkt firmy Cisco
- Nyní zdarma, otevřený kód
- Stále jednovláknový (do verze 3)
- Několik sad pravidel
 - Existují komunitní pravidla zdarma
 - Kvalitní pravidla nutno koupit
 - Pro firmu cca 10.000 Kč ročně / senzor
 - Možnost vytvářet vlastní pravidla
- Pracuje v režimech
 - HIDS, NIDS, HIPS i NIPS



Suricata

- Finančně podporována vládou USA
- Vícevláknová, větší inspekční výkon (až 10Gbps)
- Automatická detekce protokolů a typů souborů
- Vyvíjena od roku 2009
- Opensource
- Menší komunita
- Pravidla
 - Snort
 - Ne všechna lze nainportovat
 - Komunitní
 - Placená
 - Vlastní



Konfigurace a monitoring

- HW IPS
 - Většinou vzdálený přístup přes WWW rozhraní, JAVA konzolí nebo dedikovaným systémem pro současnou správu více IPS zařízení (HW zařízení nebo virtuální stroj)
- SW I[DP]S
 - Lokální konfigurační soubory
 - Monitoring WWW aplikacemi třetích stran
 - Data předávána přes spooler a následně přes MySQL databázi
 - Barnyard2 (spooler)
 - BASE
 - Snorby

Konfigurace pravidel

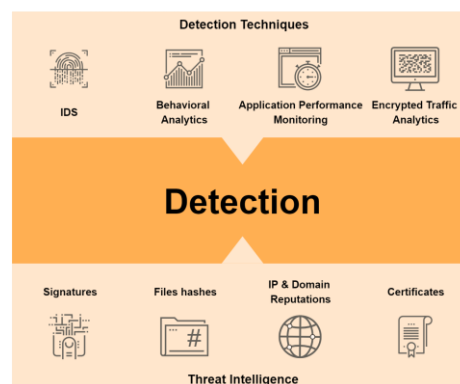
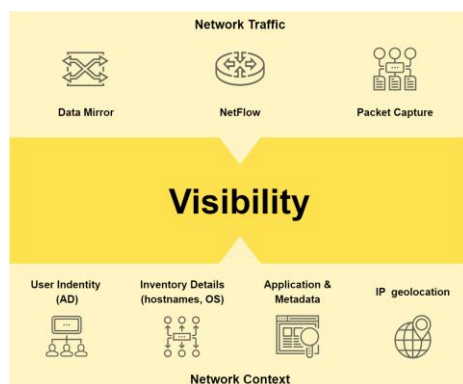
- Nejlepší praxe:
 - Provoz bez falešných zásahů má mít vždy přednost před bezpečností
 - Příliš „utažená“ pravidla způsobují falešná pozitiva
 - Profily ladíme postupně
 - Nová pravidla nejprve vyzkoušíme v režimu „upozornění“
 - Jakmile jsme si jisti, že nevytvářejí falešná pozitiva, dáme je do režimu blokování

Ukázka SELKS

- S - Suricata IDPS/NSM - <https://suricata.io/>
- E - Elasticsearch - <https://www.elastic.co/products/elasticsearch>
- L - Logstash - <https://www.elastic.co/products/logstash>
- K - Kibana - <https://www.elastic.co/products/kibana>
- S - Scirius - <https://github.com/StamusNetworks/scirius>
- EveBox - <https://evebox.org/>
- Arkime - <https://arkime.com/>
- CyberChef - <https://github.com/gchq/CyberChef>
- <https://10.60.63.202/>
 - username: selks-user
 - password: selks-user

Ukázka GREYCORTEX Mendel

- <https://www.greycortex.com/cs>



- <https://gcxa.teleinformatika.eu>
 - username: studentXX
 - password: Tele!nformatika_StudentXX
 - XX odpovídá číslu pracoviště/PC, čísla od 01 do 15

SIEM SYSTEMY

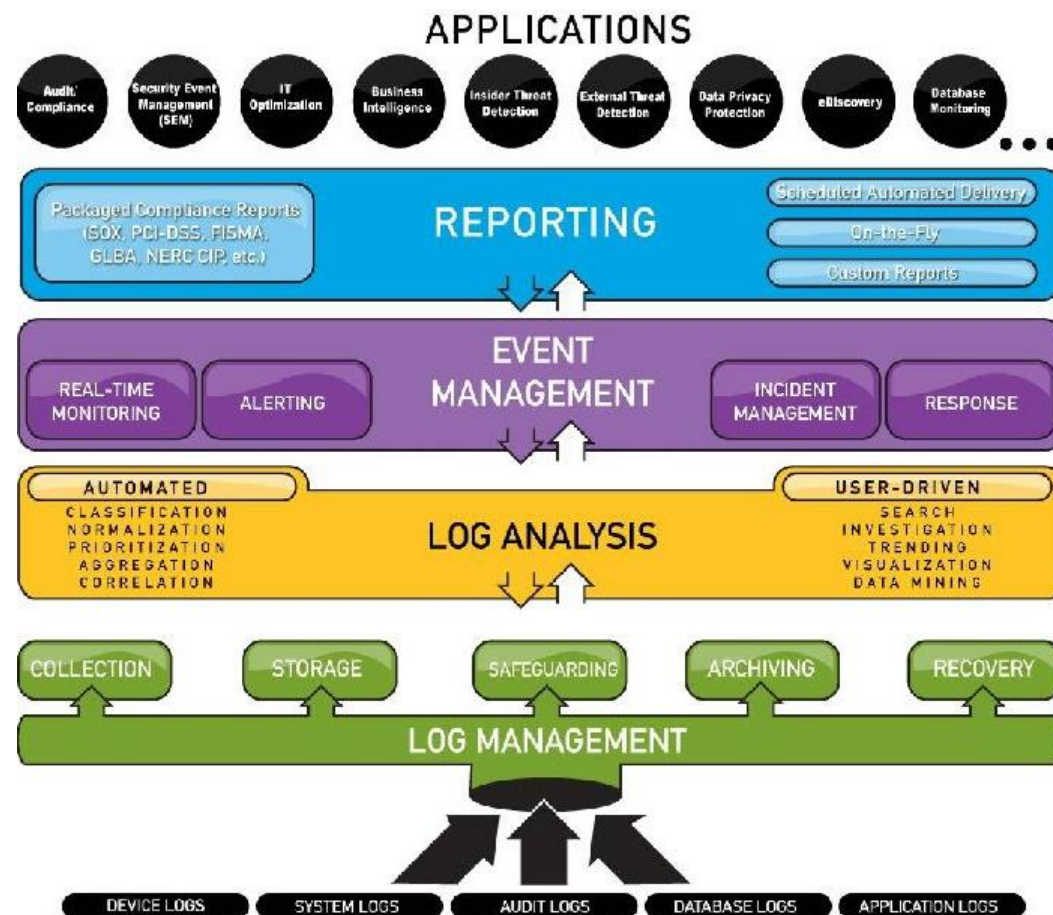
Od log managementu k SIEM

- Když surové logy nestačí
- Rozsáhlé prostředí
- Korelace v reálném čase
- Eliminace nutnosti náhledu do více konzolí
- Dodatečná indexace
- Efektivní směřování potřebných událostí
- Efektivní reporting

Hlavní funkce SIEM

- Kolekce
- Agregace
- Normalizace
- Filtrace
- Korelace
- Notifikace
- Archivace
- Retence
- Reporting

Architektura SIEM



Architektura SIEM

- Vše v jednom
 - Nižší cena HW i SW
 - Menší propustnost
 - Menší škálovatelnost
- Modulární
 - Možnost škálování
 - Větší propustnost
 - Vyšší nároky na HW
 - Vysoká dostupnost
 - Efektivnější provozní odezva
- Kombinace s modulární
 - Větší propustnost
 - Vyšší cena HW i SW

Gartner - Magický kvadrant pro SIEM



Základní podpůrné nástroje SIEM

- Testování na zranitelnosti
 - Pravidelné automatizované kontroly pomocí VA nástrojů
 - Penetrační testy při nasazení, nebo při zásadních změnách
- Evidence adresního prostoru
 - Rychlá identifikace zdroje na síti
 - Aktualizace z centrální evidence
 - Klasifikace segmentu
- Evidence systémů
 - Vkládání dodatečných informací o systému do incidentů
 - Fyzické umístění
 - Organizační jednotka
 - Správce systému
 - Klasifikace systémů

Pokročilé podpůrné nástroje SIEM

- **IAM** - identity a access management
 - Efektivní řízení přístupů dle nastavených pravidel
 - Sledování anomálií a odchylek v přístupech
 - Aktuální zobrazení informací:
 - Systém – kdo je přihlášen do systému a z jakého zdroje
 - Účet – kde všude je účet přihlášen a z jakého zdroje
- **NBAD** - detekce anomálií v síťovém provozu L3<
 - Umístění sondy na úrovni L2, nebo mirror portu
 - Sledování odchylek v chování pro:
 - zdroje a cíle spojení
 - počty spojení
 - četnost vytváření spojení
 - přenesený objem dat pro protokoly
 - časy aktivit

Pokročilé podpůrné nástroje SIEM

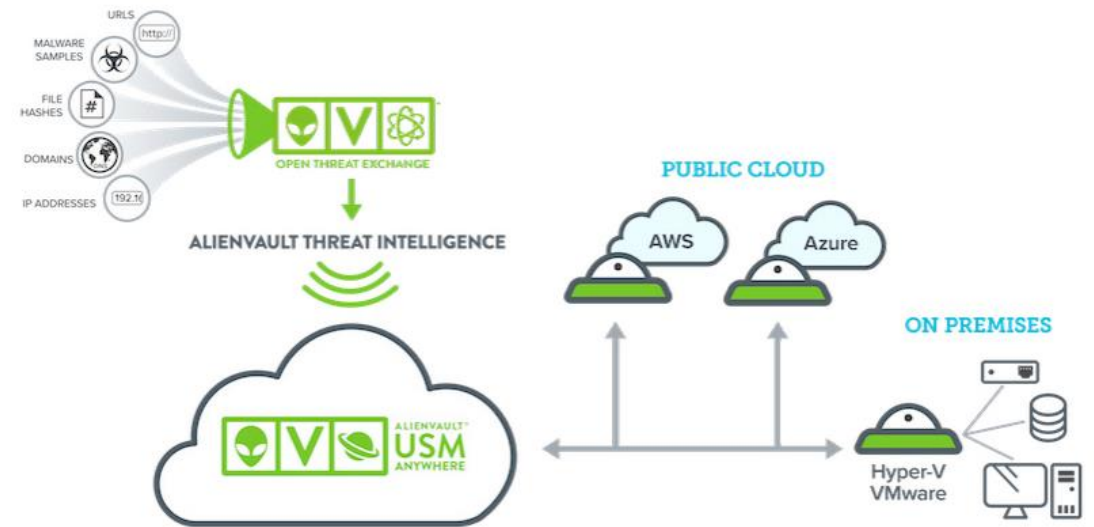
- **Sandboxing** – runtime analýza
 - Příchozí soubory z internetu - MTA, WWW, FTP
 - Analýza potencionálně infikovaných souborů
 - Zpětná analýza událostí v případě detekce anomálie
 - DNS, IP, ASN, URL
- **Darknet**
 - Alokovaný síťový prostor
 - Dříve neadresovaný prostor
 - Jakýkoliv paket je anomálie
- **Implementace principů honeypotů**
 - Honeytoken
 - Nativní honeypoty
 - Emulované honeypoty
 - V kombinaci s Darknet

Nejčastější chyby v nasazení LM nebo SIEM

- Neexistuje implementace log managementu
- Log management se řeší až v případě incidentu
- Průběžně se neověřuje obsah shromažďovaných událostí
- Malé retenční doby
- Malá propustnost řešení
- Neexistují krizové scénáře

AlienVault USM x OSSIM

- Unified Security Management (USM)
 - Placená verze
 - Plná podpora orchestrace
 - „Bohatší“ databáze
- Open Source Security Information Management (OSSIM)
 - Open-source
 - Není log management
 - Chybí podpora cloudových služeb
- <https://cybersecurity.att.com/products/ossim/compare>

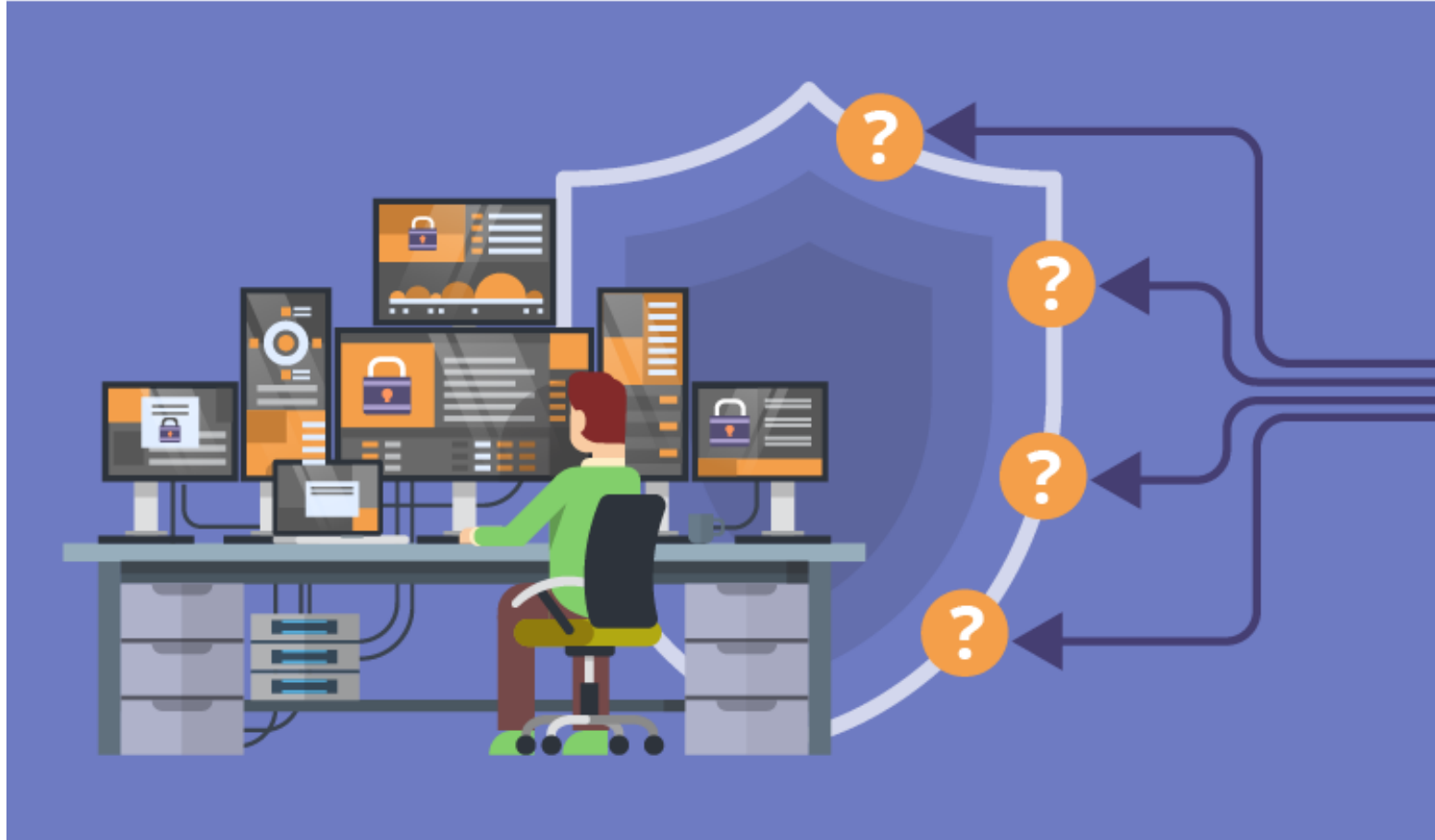


Ukázka SEIM AlienVault USM

- <https://siem.teleinformatika.eu/>
 - username: student**XX**
 - password: Tele!nformatika_Student**XX**
 - **XX** odpovídá číslu pracoviště/PC, čísla od 01 do 15

PENETRAČNÍ TESTOVÁNÍ

Penetrační testování



Typy penetračních testů

- Podle role testera
- Podle množství informací o testovaném systému
- Podle informovanosti zaměstnanců testované organizace
- Podle cíle testu

Podle role testera

- Externí
- Interní

Podle množství dostupných informací o testovaném systému

- Black-box
- White-box
- Grey-box



Podle informovanosti zaměstnanců testované organizace

- Ohlášené (se spoluprací)
- Neohlášené

Podle cíle testu

- Webové aplikace – detailní zaměření pouze na aplikaci
- Mobilní aplikace, wifi sítě, autentizační mechanismy, ...
- Testy oddělených sítí (technická síť)
- Specifické zařízení (IP telefonie, automaty, SCADA, ...)
- Testy nastavení IDS/IPS mechanismů

Fáze penetračního testování

- Určení rozsahu penetračního testování
- Výběr poskytovatele
- Příprava (účty, prostupy, oznámení, ...)
- Testování
- Závěrečná zpráva
- Vyhodnocení testu
- Závěrečná schůzka
- Odstranění nálezů

Testování

- **Plánování a průzkum** – tato fáze se skládá z pasivního a aktivního získávání informací o objednateli. Výstupem jsou rozsahy IP adres a informace o zaměstnancích (např. telefonní čísla, e-mailové adresy).
- **Skenování** – jedná se o proces testování cílené stanice se záměrem získání užitečných informací, které by mohly být využity v pozdějších fázích testování.
- **Enumerace** – je proces extrahování informací z cíleného systému z důvodu získání bližšího určení specifikací systému. Výstupem této fáze mohou být uživatelé a skupiny, sdílené složky, jména strojů atd.
- **Zisk přístupu** – jedná se o komplexní fázi, která se dělí do více kroků jako lámání hesel ke kompromitaci účtu, eskalování privilegií z běžného uživatele na administrátora apod.

Běžné problémy u penetračního testování

- Snaha vydávat sken zranitelností za penetrační testování
- Nekompetentní poskytovatel (nebo tester)
- Nedokončená práce
- Špatný odhad rozsahu testu
- Nadhodnocování/podhodnocování nálezů
- Termíny (např. nedodržení termínu, špatně zvolený termín)
- Není dodržena nezávislost testerů
- Zásahy administrátorů do průběhu testování
- Vyjmutí důležitých prvků z testování
- Nedostatečná komunikace v rámci organizace nebo s testery.

Rizika spojená s průběhem penetračního testování

- Při provádění automatizovaných testů může dojít k odmítnutí služby (DoS) nebo k omezení provozu
- Pád systému
- Zahlcení sítě
- Spuštění tiskáren
- Při testování autentizace může dojít k zablokování účtů
- Získání přístupu do systému a k získání citlivých dat
- Získání přístupu jako reálný uživatel nebo administrátor
- Nestandardní chování aplikace
- Nechtěná aktivita (např. e-maily zákazníkům)
- Průnik do cizích systémů (dodavatelé, soukromé, VPN, ...)
- Aktivace bezpečnostních mechanismů aplikace/firewallu (může dojít k zaslání oznámení administrátorovi)
- Zaplnění logovacího systému
- Poškození/zahlcení prvku nacházejícím se mezi útočícím a testovaným systémem
- Ztráta nebo znehodnocení dat
- Tvorba fiktivních registrací
- Shromažďování osobních údajů a jejich zpracovávání pro potřeby řádného provedení penetračního testování
- Při nedostatečné komunikaci může v organizaci nastat panika

Metodologie

- The Open Source Security Testing Methodology Manual (OSSTMM)
 - <https://www.isecom.org/OSSTMM.3.pdf>
- Open Web Application Security Project (OWASP)
 - <https://owasp.org/>
- NIST Cybersecurity Framework
 - <https://www.nist.gov/cyberframework>
- Cyber Assessment Framework
 - <https://www.ncsc.gov.uk/collection/caf/caf-principles-and-guidance>